

Incident Report – SOC Home Lab

Incident ID: IR-001

Analyst: Brandon Wilkinson

Severity: High

Status: Resolved (Simulated)

Executive Summary

On 2026-06-24 at 09:35:00, the Multi-Stage Attack Correlation alert triggered. Upon investigation, a port scan was initiated on the target host DESKTOP-8Q984MR followed by a brute force attempt which was successful. Further investigation led to discovering the attacker gained access to the target host via RDP. The attacker gained interactive access to the target host using compromised credentials. Recommended remediations include enforcing account lockout policies, restricting RDP access to trusted IPs and requiring multi-factor authentication for remote access.

Timeline

- | | |
|----------|--|
| 09:32:51 | Port scan detected from 192.168.10[.]20 against 192.168.10.10 |
| 09:33:17 | Brute force attempt detected against RDP (port 3389) |
| 09:35:00 | Multi-stage correlation alert fired, same source IP across both detections |
| 09:48:49 | Credentials successfully compromised, SOC Lab User account cracked after 1,860 attempts |
| 09:50:38 | Attacker established RDP session to DESKTOP-8Q984MR using compromised credentials (EventCode 4624) |
| 09:55:00 | Investigation initiated following correlation alert |
| 10:00:00 | Activity confirmed as simulated attack, Kali Linux attacker VM (192.168.10[.]20) |
-

Incident Details

Initial Detection

Multi-Stage Attack Correlation was the first triggered alert. This was due to a port scan conducted and a brute force attempt immediately following. The correlation query returns when a single IP has been detected in separate logs within a 60 minute window. This alert returned one result. Source IP 192.168.10[.]20 with a source count of 2, indicating activity across both WindowsFirewallLogs and the Security log.

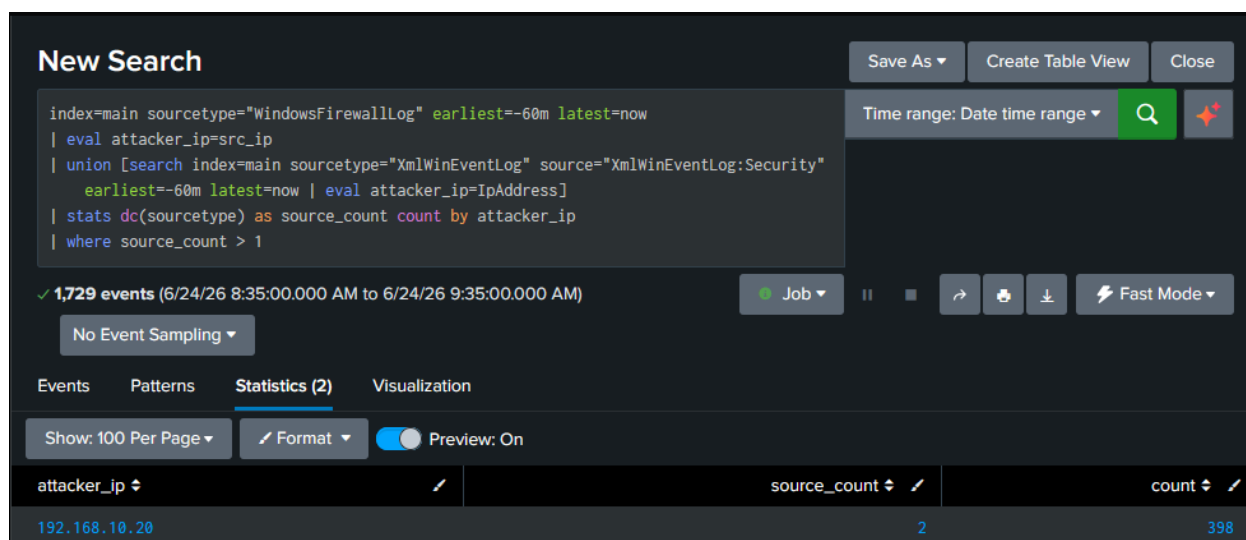


Figure 1: Shows SPL used in Multistage Attack Correlation Alert

Investigation

The first query I ran was to investigate port scan activity on the target host. I found that the source IP 192.168.10.[.]20 conducted a port scan against destination IP 192.168.10.10. This generated 12 inbound connections within a 5 minute window which exceeds the detection threshold of 10 and confirms active reconnaissance.

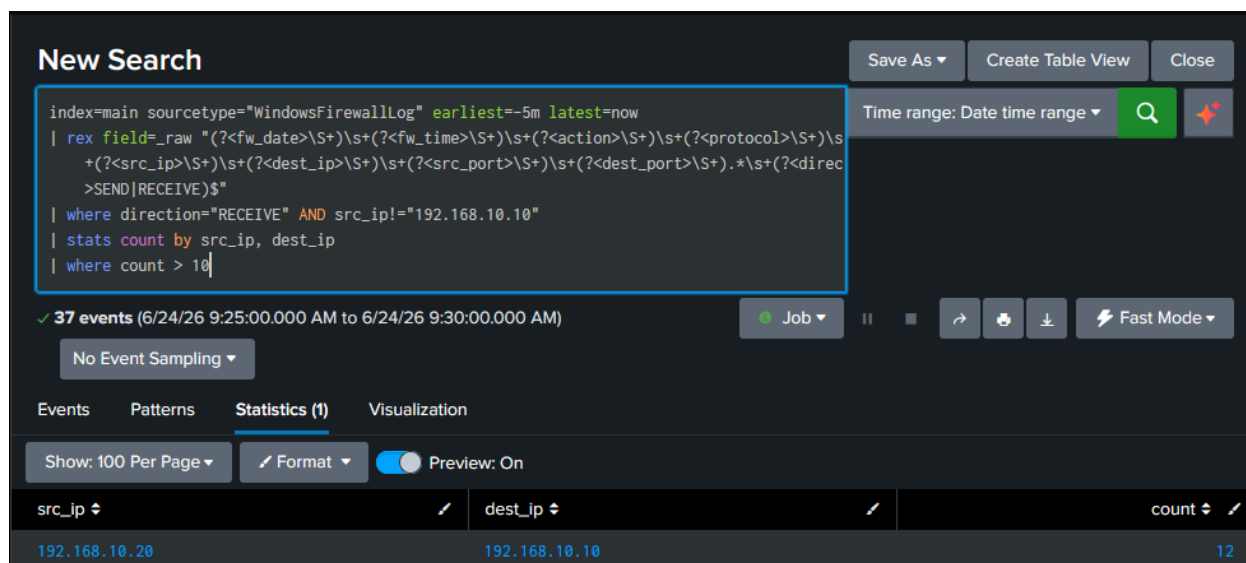


Figure 2: Query results from Port Scan search

The second query I ran was to confirm the brute force attempt on the target host. I found that between 09:33 and 09:48 there we're 1,860 failed login attempts (EventCode 4625) from 192.168.10.[.]20 against the SOC Lab User account. This volume is consistent with automated credential stuffing. The sharp drop at 09:48 indicated the brute force tool stopped, which correlated with successful credential compromise at 09:48:49.

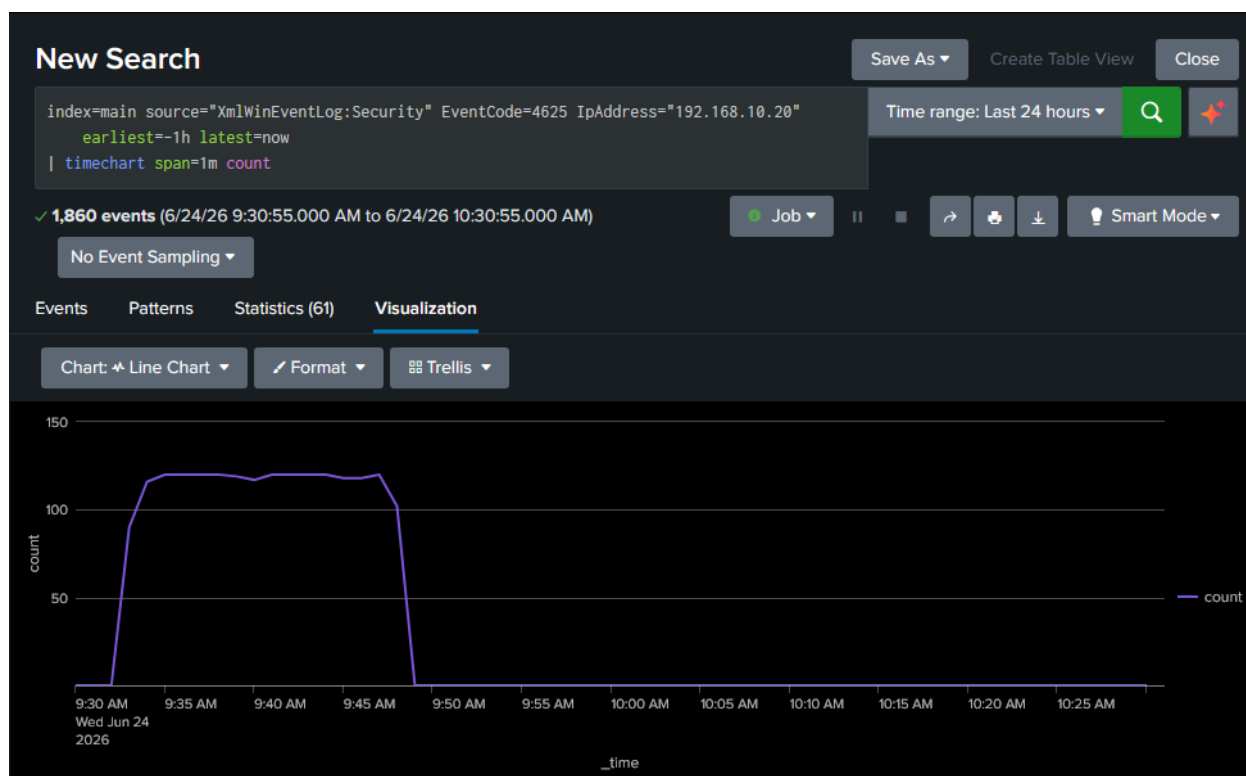


Figure 3: Graph showing failed log in attempts

The last query I ran was to check for a successful login from the attacker IP 192.168.10[.]20. The search confirmed 4 successful login events (EventCode 4624). 2 LogonType 10 (RemoteInteractive/RDP) and 2 LogonType 3 (Network). LogonType 10 confirms the attacker established an interactive RDP session on DESKTOP-8Q984MR as SOC Lab User at 09:50:38, gaining full desktop access to the target host.

The figure shows a Splunk search interface with the following details:

- Search Query:** `index=main source="XmlWinEventLog:Security" EventCode=4624 IpAddress="192.168.10.20" earliest=-4h latest=now | stats count by IpAddress, user, host, LogonType`
- Time Range:** Date time range
- Results:** 4 events (6/24/26 9:37:06.000 AM to 6/24/26 1:37:06.000 PM)
- Statistics:** A table showing the count of successful logons by IP address, user, host, and LogonType.

IpAddress	user	host	LogonType	count
192.168.10.20	SOC Lab User	DESKTOP-8Q984MR	10	2
192.168.10.20	SOC Lab User	DESKTOP-8Q984MR	3	2

Figure 4: Remote access logons

Attack Chain Reconstruction

Stage 1 — Reconnaissance (T1046)

Rapid connection attempts across multiple ports from a single source IP in a short window is a characteristic of automated scanning tools. Port 3389 was open which gave the attacker their next target.

Stage 2 — Credential Access (T1110.001)

The attacker launched an automated brute force attack against the RDP service on port 3389. There were 1856 failed login attempts against the SOC Lab User account within 15 minutes, successfully compromising the password “Password” at 09:48:49. The attacker utilized nmap to conduct port scanning (T1046) and Hydra to conduct the brute force attack (T1110.001). In a real incident, tool attribution would be inferred from attack patterns, time and any available network packet captures.

Stage 3 — Initial Access (T1021.001)

Using the compromised credentials, the attacker established an interactive RDP session (LogonType 10) on DESKTOP-8Q984MR as SOC Lab User at 09:50:38, gaining full desktop access to the target host

Indicators of Compromise

Type	Value	Description
IP Address	192.168.10[.]20	Attacker source IP (Kali VM)
EventCode	4625	Failed RDP login attempts
EventCode	4624	Successful RDP login (LogonType10)
dest_port	3389	RDP targeted
Account	SOC Lab User	Compromised account

Detection Coverage

Technique	MITRE ID	Detected Alert	
Network Port Scan	T1046	Yes	Inbound Port Scan Detection
Brute Force	T1110.001	Yes	Brute Force Attempt
Multi-Stage Correlation	T1046 + T1110.001	Yes	Multi-Stage Attack Correlation

Root Cause

The target host DESKTOP-8Q984MR had RDP exposed on port 3389 with no network-level access restrictions, a weak password on the SOC Lab User account, and no account lockout policy configured. These misconfigurations allowed the attacker to identify the open service via port scanning, conduct an unrestricted brute force attack, and ultimately compromise credentials to gain interactive access.

Recommendations

- Enforce account lockout policy
- Restrict RDP access to trusted IPs only
- Require MFA for RDP
- Monitor for brute force patterns in real time

Lessons Learned

- It is important to put together correlation searches. It makes it much easier to detect when a multi-stage attack is happening. Combining both port scan and brute force attempt alerts allowed me to see that there was actively a credential compromise to remote interactive attack occurring.
- The alert timing matters. Through my lab, I have the alerts popping on 5-minute intervals to save resources. In a real environment, this would allow the attacker to go undetected for an amount of time, rather than the alert popping the moment these things happen.
- A weak password combined with no lockout policy was the single biggest enabler of this attack. An account lockout policy of 5 attempts would have stopped this attack well before any RDP access was achieved.
- RDP exposure without network restrictions is a high-risk misconfiguration. Port 3389 should never be accessible from untrusted sources.